

Monitorización y Detección de Riesgos

Módulo 12 · Seguridad en IA

Métricas de seguridad, detección de ataques activos, drift, dashboard mínimo, logs inmutables y compliance.

1. Introducción · 2. Qué es · 3. Cómo funciona · 4. Ejemplos reales
5. Errores comunes · 6. Aplicación práctica · 7. Relación con módulos · 8. Resumen ejecutivo

Guía de estudio detallada · +2.000 palabras

Monitorización y Detección de Riesgos en Sistemas LLM

La seguridad de los sistemas LLM no es un estado que se logra en el despliegue: es un proceso continuo de monitorización, detección, y respuesta. Los ataques evolucionan constantemente, los modelos cambian de comportamiento con las actualizaciones, el corpus RAG se actualiza y puede introducir nuevo contenido, y las pautas de uso del sistema por parte de los usuarios cambian con el tiempo. Sin monitorización continua, el sistema puede estar siendo atacado durante semanas o produciendo outputs dañinos sin que el equipo lo sepa.

El framework NIST AI RMF nombra explícitamente los ejercicios continuos de red teaming como una "medida de seguridad central" y el EU AI Act artículo 15 requiere robustez y ciberseguridad continua para sistemas de alto riesgo. La monitorización de seguridad de LLMs se distingue de la monitorización de calidad (vista en M8-T7) en que se centra específicamente en detectar amenazas activas, comportamientos fuera de política, y patrones que indican un ataque en curso.

Las dimensiones de la monitorización de seguridad LLM

Detección de ataques activos

La detección de ataques activos monitoriza las interacciones en tiempo real para identificar patrones que indican un intento de ataque: frecuencia alta de inputs que trigger los filtros de seguridad (puede indicar un atacante probando variantes), inputs con patrones de codificación inusual (Base64, Unicode especial), secuencias de conversación que escalan gradualmente hacia contenido prohibido (multi-turn jailbreak), y ráfagas de peticiones desde el mismo usuario/IP con variaciones sistemáticas del mismo prompt (fuzzing automatizado).

Detección de comportamientos fuera de política

La detección de comportamientos fuera de política identifica outputs del sistema que no cumplen las políticas definidas aunque no sean el resultado de un ataque: respuestas que revelan el system prompt, outputs que incluyen datos de otros usuarios (violación de aislamiento de tenants), outputs en categorías de contenido no permitido, respuestas que incluyen información de herramientas internas (URLs de sistemas internos, nombres de bases de datos, credenciales), y desviaciones del tono o estilo definido para el sistema.

Detección de drift y anomalías

El drift de comportamiento del sistema puede ser gradual e invisible sin monitorización activa: cambios en la distribución estadística de los outputs, aumento gradual de la tasa de contenido que trigger los filtros, cambios en la distribución de las categorías de preguntas (puede indicar que un nuevo tipo de usuario está usando el sistema con diferentes intenciones), y cambios en el comportamiento del modelo después de una actualización del proveedor que no fueron detectados en el testing pre-despliegue.

Implementación de monitorización de seguridad

Métricas de seguridad para el dashboard

Las métricas de seguridad que monitorizar continuamente: tasa de inputs bloqueados por filtros (baseline y alertas por desviaciones significativas), tasa de outputs bloqueados por filtros, tasa de contenido que triggea categorías de riesgo específicas (hate speech, dangerous activities, etc.), distribución de usuarios/IPs que generan los inputs de más alta tasa de filtrado, latencia de los sistemas de filtrado (si los filtros se ralentizan, puede indicar sobrecarga o ataque de denegación de servicio), y tasa de consumo de tokens anómala (puede indicar DoS o cost amplification attack).

Alertas y respuesta a incidentes

Define umbrales de alerta basados en la variabilidad natural del sistema. Las alertas de seguridad críticas (que requieren respuesta inmediata): output que revela datos confidenciales de otros usuarios, tasa de contenido de categoría A (las más dañinas) superior al 0.1% en una ventana de 1 hora, uso de la cuenta de un usuario suspendido, o ráfaga de >1.000 peticiones en 5 minutos desde la misma IP. Las alertas de seguridad informativas (que requieren investigación): aumento del 50% en la tasa de filtrado respecto al baseline diario, o aparición de un nuevo patrón de ataque que no estaba en el baseline.

Forensics: reconstruir un incidente de seguridad

Los logs de auditoría completos (inputs, outputs con timestamps, resultados de filtros, usuario, sesión) permiten reconstruir cualquier incidente de seguridad: qué inputs llevaron al comportamiento anómalo, qué pasos del pipeline fallaron o fueron eludidos, cuándo comenzó el ataque y cuánto duró, y qué datos o acciones fueron afectadas. El NIST Cybersecurity Framework recomienda que los logs de seguridad se retengan mínimo 12 meses para incidentes activos y 90 días para el flujo normal.

SECCIÓN 4 · EJEMPLOS REALES

- Detección temprana de ataque de exfiltración (empresa de seguros, 2025): el dashboard de monitorización detectó una anomalía: un usuario específico estaba generando conversaciones 3x más largas que el promedio, con consultas que seguían un patrón sistemático de variaciones sobre el mismo tema. El análisis reveló un intento de multi-turn jailbreak para extraer información de la política de suscripción. El usuario fue bloqueado preventivamente antes de que el jailbreak tuviera éxito. Sin la monitorización de patrones anómalos, el ataque podría haber continuado indefinidamente.
- Detección de drift de comportamiento post-update (banco digital, 2024): una actualización silenciosa del modelo subyacente cambió su comportamiento en respuestas sobre productos de alto riesgo. El dashboard de monitorización detectó un aumento del 40% en la tasa de respuestas que triggean el filtro de "productos financieros de alto riesgo" comparado con el baseline de la semana anterior. La investigación reveló que el nuevo modelo era más propenso a discutir productos especulativos. Se reversionó al modelo anterior en 4 horas.
- Monitorización de consumo anómalo (plataforma SaaS de IA, 2024): un usuario empezó a enviar requests con prompts de 50.000 tokens a las 3am. Sin rate limiting por TPM,

consumió 2.000 dólares de crédito de API en 20 minutos. El dashboard de monitorización de consumo detectó la anomalía en el minuto 3 y bloqueó la cuenta automáticamente. Sin la alerta, el consumo habría continuado hasta agotar el presupuesto mensual en horas.

SECCIÓN 5 · ERRORES Y MALENTENDIDOS COMUNES

Error 1: Monitorizar solo errores técnicos (HTTP 5xx) sin monitorizar comportamiento de seguridad. Un sistema que responde con HTTP 200 pero produce outputs que revelan datos confidenciales está funcionando "correctamente" desde el punto de vista técnico pero tiene un incidente de seguridad activo. La monitorización de seguridad debe ir más allá de los errores técnicos.

Error 2: Logs de auditoría sin retención adecuada. Los incidentes de seguridad pueden no detectarse inmediatamente. Un ataque que extrae información de forma gradual a lo largo de semanas solo es visible en retrospectiva si se tienen los logs completos del período. Define políticas de retención de logs específicas para seguridad (mínimo 12 meses para sistemas críticos).

Error 3: No testear el sistema de alertas periódicamente. Un sistema de alertas que no genera alertas puede ser porque todo está bien o porque el sistema de alertas está roto. Genera alertas de prueba periódicamente (fire drill de seguridad) para verificar que los sistemas de detección y notificación funcionan correctamente.

SECCIÓN 6 · APLICACIÓN PRÁCTICA

El dashboard mínimo de monitorización de seguridad LLM: (1) tasa de inputs bloqueados/hora (alerta si >2x el baseline), (2) tasa de outputs bloqueados/hora (alerta si >2x el baseline), (3) distribución de categorías de riesgo en outputs (alerta si categoría crítica supera umbral), (4) consumo de tokens por usuario/hora (alerta si >10x el promedio del usuario), (5) tasa de respuestas sospechosas (outputs que revelan system prompt o datos de otros usuarios). Frecuencia de revisión: tiempo real para alertas críticas, diario para el dashboard completo.

Para implementar detección de patrones de ataque con LangSmith: configura evaluadores LLM-as-judge que clasifiquen una muestra diaria de las interacciones según categorías de riesgo de seguridad. Define alertas en LangSmith cuando las métricas de seguridad superen los umbrales. Para detección en tiempo real, implementa un middleware en el API Gateway que analiza los headers y el tamaño del request para detectar patrones de DoS/fuzzing antes de que lleguen al modelo.

SECCIÓN 7 · RELACIÓN CON OTROS MÓDULOS

- M8-T7 (Observabilidad LLMOps): la monitorización de seguridad complementa la monitorización de calidad con dimensiones de riesgo.
- M12-T9 (Red teaming): el red teaming periódico simula los ataques que la monitorización debe detectar.
- M13 (Gobernanza): los requisitos de logging y auditoría de la monitorización de seguridad son parte del cumplimiento del AI Act.

SECCIÓN 8 · RESUMEN EJECUTIVO

La monitorización de seguridad LLM detecta: ataques activos (patrones de input sospechosos, fuzzing, multi-turn jailbreaks), comportamientos fuera de política (outputs que revelan system prompt, datos de otros tenants), y drift/anomalías (cambios en la distribución de outputs que pueden indicar compromiso o actualización silenciosa del modelo). Las métricas del dashboard mínimo: tasa de filtrado de input/output, categorías de riesgo, consumo anómalo por usuario. Los logs deben retenerse mínimo 12 meses y deben ser inmutables en sectores regulados. El NIST AI RMF y el EU AI Act requieren monitorización continua de seguridad para sistemas de alto riesgo.